
EU Chat Control and Client-Side Scanning

Harrys Kavan

ir241506@fhstp.ac.at

FH St. Pölten

2025-10-11

ABSTRACT

The European Commission’s proposal on combating child sexual abuse introduces detection orders that would mandate client-side scanning (CSS) inside end-to-end encrypted (E2EE) messaging platforms. This paper surveys the technical feasibility of CSS, the security regressions it triggers, and the evolving EU legal context. I synthesise current literature on perceptual hashing, private set intersection, and machine-learning (ML) classifiers, highlight their vulnerability to adversarial manipulation, and evaluate how they collide with the forward-secrecy and post-compromise security promises of modern protocols such as Messaging Layer Security (MLS) and Signal. Regulatory documents from the European Parliament, the European Data Protection Board, and recent human-rights jurisprudence illustrate the proportionality and governance concerns. I map the primary risks, stakeholder incentives, and alternative safety measures to outline policy options that preserve E2EE guarantees while addressing legitimate child-safety goals.

Keywords EU Chat Control · Client-Side Scanning · End-to-End Encryption · CSAR

Disclosure: I used generative artificial intelligence tools to proof-read and polish this paper; all research and conclusions are my own.

1 Introduction & Definitions

The European Commission’s draft Child Sexual Abuse Regulation (CSAR) would let national authorities issue detection orders that force messaging services to run scanning technology, even when those services rely on end-to-end encryption (E2EE) [1]. Under the shorthand “EU Chat Control,” the proposal also sketches an EU Centre that would manage shared indicator databases and coordinate requests to include grooming and newly discovered child sexual abuse material (CSAM). Modern E2EE protocols such as Messaging Layer Security (MLS) keep message contents confined to the endpoints and promise forward secrecy (FS) and post-compromise security (PCS) [2], so any mandate to scan content before encryption directly challenges that trust model.

While the regulatory debate has advanced, public awareness has not kept pace. Swedish interviews carried out in 2025 show that even digitally literate adults know little about Chat Control, which raises questions about informed consent to far-reaching surveillance changes [3]. This paper therefore examines the technical feasibility of client-side scanning (CSS), the

trade-offs it creates for E2EE services, and the evolving legal and social context in which EU lawmakers are working.

2 Technical Feasibility of CSS in E2EE Environments

Most CSS designs mix three ingredients: perceptual hashes for known imagery, private set intersection (PSI) to test membership without revealing whole databases, and threshold reporting that fires only after several matches. Apple’s 2021 proposal is the best documented example. It blinded PhotoDNA-style hashes, used PSI with associated data, and issued encrypted vouchers once an account crossed a preset trigger [4], [5]. The architecture shows that on-device matching is technically achievable, but it also underlines how much depends on trusted hash updates, disciplined software supply chains, and tamper-resistant client devices.

Security research points out where that idealised model frays. Deep perceptual hashing networks can be nudged into collisions, allowing benign files to masquerade as illegal content or vice versa [6]. Experiments presented at the 2024 Network and Distributed System Security Symposium (NDSS) further note that distributing scanning logic to millions of heterogeneous phones and laptops widens the attack surface for both physical and remote adversaries [7]. Providers have floated on-device machine-learning classifiers to catch unknown material, yet those models still show high false-positive and false-negative rates and there is little publicly verifiable evidence that governance processes can keep up [8]. Providers generally keep hash lists and model weights private to frustrate evasion, which limits the opportunities for outside review.

Real-world incidents show the stakes; documented false positives and lengthy appeals are discussed in the Risk Landscape section.

3 Key Management Realities in Modern E2EE

Detection orders often assume that governments or trusted proxies can trigger scanning without weakening encryption. The actual key flows in popular apps look very different. Services generate and store long-term keys on user devices, protect them in secure hardware where possible, and replicate them through end-to-end encrypted backup systems. Apple’s Advanced Data Protection keeps recovery material inside the user’s control, so the company cannot restore content if those keys are lost [9]. MLS refreshes group secrets whenever membership changes to preserve FS and PCS [2]. Signal mirrors those ideas in production by limiting each account to one primary phone plus a handful of linked desktops and by exposing safety numbers so contacts can verify keys [10], [11]. WhatsApp takes a similar stance: re-registering on a new phone logs out every other device automatically, forcing a fresh trust reset [12].

Any mandated escrow or quiet plaintext exfiltration would undo these protections. It would also create tempting downgrade paths for attackers who can already target backup or multi-device flows. In short, the points where CSS would have to hook into E2EE systems are exactly the points that engineers have spent the last decade hardening.

4 Government Access Models and Legal Context

CSAR detection orders would only follow after a service-specific risk assessment and, under the European Parliament’s (EP) mandate, would have to stay targeted rather than blanket [1]. The EP’s 2023 position explicitly excludes E2EE services for that reason and the European Data

Protection Board (EDPB) backed that carve-out, warning that indiscriminate scanning would clash with the Charter of Fundamental Rights [13], [14]. The European Court of Human Rights delivered a similar message in the 2024 Podchasov ruling: undermining encryption opens the door to general surveillance and fails the proportionality test [15].

Political backing for stronger obligations is also fractured. Germany, Poland, Austria, Estonia, Slovenia, and Luxembourg have formally challenged earlier drafts on rights grounds, which leaves the Council short of consensus [3]. Unless lawmakers can show that CSS is both necessary and technically dependable, the legal path to intrusive detection orders remains narrow.

5 Openness, Auditability, and Update Governance

CSS inherits longstanding tensions between proprietary safety tooling and the transparency expectations of cryptographic systems. Server-side PhotoDNA remains closed-source, constraining external verification of bias, robustness, and scope expansion risks [16]. Meta’s open-source PDQ hash offers greater auditability for matching known contraband, yet even open algorithms still rely on trusted distribution of hash corpora and model updates [17]. Apple’s CSS design required periodic delivery of blinded hash sets and machine-learning weights, verified through code signing and secure boot chains [4]. Mandated CSS would have to formalise similar update mechanisms, but questions persist over who curates the datasets, how appeals against incorrect inclusion operate, and how independent experts can inspect tooling without leaking sensitive material. Requiring client attestation to enforce CSS also risks entrenching closed ecosystems and excluding alternative clients, undermining interoperability goals embedded in other EU digital policy packages.

6 Risk Landscape

CSS pushes sensitive decisions to the edges of the network, which compounds several kinds of risk. On the technical side, attackers can force or dodge perceptual hash matches, tamper with on-device models, or exploit the larger attack surface that comes with millions of scanning clients [6], [7]. Secret hash lists and opaque machine-learning (ML) updates may delay adversaries, but they also invite mission creep because external reviewers cannot see when the scope expands [3], [18].

The human impact is just as visible. Swedish survey data show that students who learn about Chat Control treat it as a real threat, report heightened privacy anxiety, and lean on emotional support rather than technical fixes [19]. Interviewees describe how they already adjust their behaviour, ranging from “nothing to hide” resignation to fears that pervasive scanning will normalise pre-emptive monitoring [3]. Documented false positives make those worries concrete: Microsoft misread family photos as contraband and locked the owner out of his account, while Google’s automated systems flagged medical pictures of a toddler and triggered a police investigation [20], [21].

These stories also align with theory. Protection Motivation Theory treats fear as only a partial mediator in privacy contexts, with sustained anxiety directly shaping how people appraise threats and choose coping strategies [19]. Governmentality and risk-society perspectives help explain why some users accept surveillance as the price of safety even when the evidence of harm keeps growing [3].

Risk	Likelihood	Impact	Mitigations	Residual risk
Hash collisions or adversarial evasion	High	High	Multi-hash verification; human analyst review	Medium
Automated false positives triggering account sanctions	Medium	High	Escalate to human triage; guaranteed appeals	Medium
machine-learning (ML) false negatives on novel material	Medium	High	Diverse training data; post-incident feedback loops	Medium
Generalised monitoring of private communications	Medium	High	Strict targeting; judicial warrants	Low to medium
Device compromise expands surveillance	Medium	High	Hardening clients; minimise data retention	Medium
Chilling effects and self-censorship	Medium	Medium to high	Transparency; narrow legal scope; redress mechanisms	Medium
Mission creep and scope expansion	Medium to high	High	Statutory purpose limits; independent audits	Medium

7 Stakeholder Perspectives

Balancing child safety and privacy demands a clear view of who is affected and what they value. Survivors’ advocates and law-enforcement agencies push for faster identification of abuse material but still need reliable evidence chains and proportionate procedures [22]. Platform operators must harmonise regulatory demands across jurisdictions while keeping user trust. Cryptographers and civil-society groups defend FS/PCS guarantees and transparent governance [8]. End users—including minors—look for private day-to-day communications and sensible recovery paths, yet their tolerance for false positives is understandably low.

- Survivors and advocacy groups: Need rapid takedowns and trustworthy escalation paths while avoiding retraumatisation from false positives.
- Law-enforcement authorities: Seek actionable evidence and timely referrals that hold up in court without collapsing legal safeguards.

- Platform operators: Balance regulatory compliance with user trust, cross-border interoperability, and operational cost.
- Security and cryptography community: Defend FS/PCS guarantees and insist on transparent, verifiable safety tooling.
- End users (including minors): Expect private communications, intuitive recovery, and protection from both abuse and unwarranted surveillance.
- Students and young adults: Swedish survey participants report heightened privacy anxiety and rely on emotional support rather than technical coping, signalling resilience costs [19].
- General citizens: Interviews reveal limited baseline knowledge of Chat Control alongside divergent fairness intuitions—from “nothing to hide” acceptance to fears of Pandora’s box [3].
- Regulators and policymakers: Must reconcile child-protection mandates with Charter rights and proportionality obligations.

8 Open Problems and Research Gaps

The existing CSS literature lacks agreed-upon metrics for acceptable false-positive and false-negative rates in legal contexts, especially for emergent ML-based classifiers. Governance frameworks for curating and auditing hash databases remain ad hoc, with few statutory safeguards for error correction or dataset scope creep. Robust remote attestation for heterogeneous consumer devices is also unsolved; without it, malicious actors can bypass mandated scanning while honest users shoulder the privacy costs. Finally, empirical studies on how CSS might interact with new multi-device E2EE protocols such as MLS are sparse, leaving regulators without evidence on whether detection orders could ever be enforced without breaking protocol guarantees.

9 Alternatives and Complementary Measures

Several privacy-preserving safety controls already exist that do not require breaking E2EE. Recipient-initiated reporting lets victims share selected messages in plaintext when they decide to escalate [23]. Metadata and behavioural cues—such as flagging high-volume forwards or rapid group creation—can surface risky patterns while leaving content encrypted [12]. Safety-by-design work adds friction to unsolicited contact and improves moderation in semi-public spaces [22]. Additional investment in survivor support and cross-border cooperation boosts response capacity without changing cryptographic guarantees.

- Recipient-initiated reporting: Preserves user agency and E2EE while supplying plaintext when harm occurs; limited for proactive detection.
- Metadata risk scoring: Highlights abusive coordination patterns with lower privacy exposure; effectiveness declines on truly novel content.
- Safety-by-design defaults: Adds friction to unsolicited contact and automates protective responses; requires continuous user experience (UX) investment.
- Guardian-mediated local scanning: Apple-style Communication Safety keeps analysis on-device with parental control and no provider reporting; unsuitable for mandated law-enforcement agency (LEA) workflows [3].
- Server-side scanning of non-E2EE surfaces: Leverages mature PhotoDNA deployment on cloud storage and public channels; does not reach private encrypted messaging.
- Survivor support and cross-border cooperation: Improves investigative throughput and victim care without touching encryption keys.

10 Policy Options and Conclusion

Given the unsettled technical picture and unresolved legal objections, the most defensible near-term move is to anchor the EP’s targeted-detection stance. Services that offer strong E2EE should remain outside mandatory CSS unless they volunteer a design that independent experts can verify. Regulators can still raise the safety bar by demanding transparency reports, funding audits for hash and model governance, and supporting common tooling for recipient-initiated workflows. If CSS proposals resurface, they must come with certified datasets, clear error budgets, and sunset clauses to prevent scope creep. Until such evidence exists, lawmakers are better served by strengthening alternatives that respect the confidentiality guarantees underpinning secure communications [13], [14].

Bibliography

- [1] E. Commission, “Proposal for a Regulation of the European Parliament and of the Council laying down rules to prevent and combat child sexual abuse.” [Online]. Available: <https://eur-lex.europa.eu/legal-content/EN/TXT/?uri=COM%3A2022%3A209%3AFIN>
- [2] R. Barnes, B. Beurdouche, B. Robert, M. Thomson, and E. Yoshino, “The Messaging Layer Security (MLS) Protocol,” 2023. [Online]. Available: <https://www.rfc-editor.org/rfc/rfc9420.pdf>
- [3] E. Lindholm, “Chat Control, Fundamental Rights, and Public Awareness,” 2025.
- [4] Apple, “CSAM Detection – Technical Summary,” 2021. [Online]. Available: https://www.apple.com/child-safety/pdf/CSAM_Detection_Technical_Summary.pdf
- [5] A. Bhowmick, M. Cunche, L. Olejnik, and M. W"ahlsch, “The Apple PSI System: Security Protocol and Analysis,” 2021. [Online]. Available: https://www.apple.com/child-safety/pdf/Apple_PSI_System_Security_Protocol_and_Analysis.pdf
- [6] M. A. Struppek, J. Geiping, M. Moeller, and M. Keuper, “Learning to Break Deep Perceptual Hashing: The Use Case NeuralHash,” *arXiv*, no. 2111.06628, 2021, [Online]. Available: <https://arxiv.org/abs/2111.06628>
- [7] A. Hooda and others, “Experimental Analyses of the Physical Surveillance Risks in Client-Side Content Scanning,” in *Network and Distributed System Security Symposium (NDSS)*, 2024. [Online]. Available: <https://www.ndss-symposium.org/wp-content/uploads/2024-1401-paper.pdf>
- [8] H. Abelson *et al.*, “Keys Under Doormats: Mandating Insecurity by Requiring Government Access to All Data and Communications,” *Communications of the ACM*, vol. 58, no. 10, pp. 24–26, 2015, doi: [10.1145/2810103](https://doi.org/10.1145/2810103).
- [9] Apple, “Apple Platform Security,” 2025. [Online]. Available: https://help.apple.com/pdf/security/en_US/apple-platform-security-guide.pdf
- [10] Signal, “Linked Devices.” [Online]. Available: <https://support.signal.org/hc/en-us/articles/360007320551-Linked-Devices>
- [11] Signal, “What is a safety number and why do I see that it changed?.” [Online]. Available: <https://support.signal.org/hc/en-us/articles/360007060632-What-is-a-safety-number-and-why-do-I-see-that-it-changed>

- [12] WhatsApp, “About Lost or Stolen Phones and Accounts.” [Online]. Available: <https://faq.whatsapp.com/1131652977717250>
- [13] E. Parliament, “Legislative Train: Combating Child Sexual Abuse Online.” [Online]. Available: <https://www.europarl.europa.eu/legislative-train/spotlight-JD22/file-combating-child-sexual-abuse-online>
- [14] E. D. P. Board, “Statement 1/2024 on the Proposal for a Regulation laying down rules to prevent and combat child sexual abuse,” 2024. [Online]. Available: https://www.edpb.europa.eu/system/files/2024-02/edpb_statement_202401_proposal_regulation_prevent_combat_child_sexual_abuse_en.pdf
- [15] E. C. of Human Rights, “Podchasov v. Russia, Application no. 1094/19.” [Online]. Available: <https://hudoc.echr.coe.int/eng?i=001-231925>
- [16] Microsoft, “PhotoDNA.” [Online]. Available: <https://www.microsoft.com/en-us/photodna>
- [17] Meta, “PDQ and TMK+PDQF: Open Source Perceptual Hashing Tools.” [Online]. Available: <https://github.com/facebook/ThreatExchange>
- [18] E. D. P. Board and E. D. P. Supervisor, “Joint Opinion 04/2022 on the Proposal for a Regulation laying down rules to prevent and combat child sexual abuse,” 2022. [Online]. Available: https://edpb.europa.eu/system/files/2022-07/edpb-edps_jointopinion_2022-04_en.pdf
- [19] L. Andersson, “Perceptions of EU Chat Control: A Protection Motivation Theory Study among Swedish Students,” 2025.
- [20] S. Nilsson, “False Positives and Collateral Harm in Automated CSAM Detection,” 2025.
- [21] K. Hill, “A Dad Took Photos of His Toddler for the Doctor. Google Flagged Him as a Criminal,” *The New York Times*, Aug. 2022, [Online]. Available: <https://www.nytimes.com/2022/08/21/technology/google-surveillance-toddler-photo.html>
- [22] Ofcom, “Consultation: Technology Notices,” 2024. [Online]. Available: <https://www.ofcom.org.uk/siteassets/resources/documents/consultations/category-1-10-weeks/consultation-technology-notices/main-document/technology-notices-consultation.pdf>
- [23] Meta, “Messenger End-to-End Encryption Overview,” 2023. [Online]. Available: https://engineering.fb.com/wp-content/uploads/2023/12/MessengerEnd-to-EndEncryptionOverview_12-6-2023.pdf

APPENDIX A

A.1 Prompt Used

Please proof-read and improve the readability of my Typst paper on EU Chat Control while keeping the structure, citations, and original analysis intact. Suggest clearer wording where needed, ensure abbreviations are introduced, and polish the bibliography formatting.

A.2 Search Log

- web.run → “CSAM Detection Technical Summary” → captured Apple’s blinded-hash design and PSI workflow
- web.run → “Apple PSI System” → sourced Bhowmick et al.’s protocol analysis
- web.run → “NDSS 2024 client-side scanning risks” → located Hooda et al. on adversarial threats
- web.run → “RFC 9420 PDF” → obtained MLS specification
- web.run → “EDPB Statement 2024 CSAR” → gathered regulator position on detection orders
- web.run → “European Parliament legislative train child sexual abuse” → tracked negotiation status updates
- web.run → “Messenger E2EE abuse reporting” → confirmed recipient-initiated reporting documentation
- arxiv.is → “Chat Control” → checked for recent preprints on CSS policy debates
- Google Scholar → “EU Chat Control CSS 2025” → surfaced 2025 theses on public perceptions and legal framing